PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Mécanismes de sécurité Windows Server

06-660 PSE 25-27 5-8 Windows Server - Mécanismes de sécurité — source : fiche de révision du module (gemma4, 03/11/2026)

À RETENIR

1. L'authentification vérifie l'identité tandis que l'autorisation détermine les droits accordés après la vérification.
2. Le processus LSASS.EXE héberge les fonctionnalités de l'autorité de sécurité locale pour l'authentification.
3. Le protocole Kerberos utilise des tickets pour permettre l'authentification unique dans un domaine Active Directory.

Fondamentaux de la sécurité Windows

Notion	À retenir
Objectifs de sécurité	Protéger contre les **accès non autorisés** via la **confidentialité**, l'**intégrité**, la **disponibilité**, l'**authentification** et la **traçabilité**.
Authentification vs Autorisation	L'**authentification** vérifie l'identité (**qui** est l'utilisateur) ; l'**autorisation** détermine les droits (**ce qu'il peut faire**) après vérification.
Composants essentiels	Comptes, groupes, **SID**, **jetons d'accès**, **ACL**, stratégies, **GPO**, **LSASS.EXE** (LSA), **Winlogon.exe**, **SSPI**, **SAM** (local) ou **Active Directory** (domaine).

Identités, SID et jetons

Notion	À retenir
Principaux et SID	Un **principal** (**utilisateur**, **groupe**, **ordinateur** ou **service**) possède un **SID** unique. Les autorisations sont liées au **SID**, pas au nom.
Jeton d'accès	Créé après authentification : SID de l'utilisateur et des groupes, **privilèges**. Le mot de passe **prouve** l'identité, le jeton la **représente** lors des contrôles d'autorisation.
Vérification de l'identité	Identification → authentification → **jeton d'accès** → demande d'accès → comparaison jeton / autorisations → accès **autorisé** ou **refusé**.

Architecture et composants du système de sécurité

Notion	À retenir
Modèle et flux	Contrôle via **identité** et **droits** ; flux : **authentification** → construction du **contexte de sécurité** (**jeton d'accès**) → **autorisation/refus** → **audit**.
SAM vs AD	Comptes locaux dans la base `SAM` (**Security Accounts Manager**) sur serveur autonome ; comptes du domaine dans la base **Active Directory** sur les **contrôleurs de domaine**.
LSA, LSASS, Winlogon	**LSA** : traite l'ouverture de session et applique la stratégie ; **LSASS.EXE** : héberge les fonctionnalités de la LSA ; **Winlogon.exe** : gère l'ouverture de session **interactive**.
Interface SSPI	Fournit une **interface commune** pour masquer aux applications les détails techniques des protocoles (**Kerberos**, **NTLM**, **Negotiate**, **Schannel** ou **Digest**).

Protocoles et services d'authentification

Notion	À retenir
Kerberos et KDC	Protocole **version 5** privilégié. Utilise des **tickets** pour éviter de transmettre le mot de passe. Le **KDC** est intégré aux contrôleurs de domaine via **Active Directory**.
NTLM et Negotiate	NTLM utilise le **challenge/réponse**. Le mode **Negotiate** choisit **Kerberos** par défaut ou bascule sur **NTLM** si Kerberos est indisponible.
Schannel	Fournit la sécurité pour **TLS** et **SSL** via le **chiffrement** et l'**authentification**. Accessible aux applications par l'architecture **SSPI**.

Recommandations de sécurité

Notion	À retenir
Permissions NTFS et ACL	Attribuer des permissions (**lecture**, **écriture**, **modification**, **contrôle total**) via des **ACE** (identité + droits) contenues dans une **ACL**.
Principe du moindre privilège	Donner **uniquement les droits nécessaires** aux tâches pour limiter l'impact d'une **erreur humaine**, **compromission de compte**, **logiciel malveillant** ou **mauvaise configuration**.
Utilisation des GPO	Centraliser la configuration (**mots de passe**, **pare-feu**, **audit**, **restrictions**, **Windows Defender**) et distribuer les paramètres via **Active Directory**.
Pare-feu et Windows Defender	Le **Pare-feu Windows Defender** contrôle les flux **entrants/sortants** pour limiter l'exposition des services ; **Windows Defender** protège contre les **logiciels malveillants**.

Audit, session et analyse

Notion	À retenir
Stratégies d'audit	Permettent de distinguer les événements **réussis** des **échecs**. Consultables via l'**Observateur d'événements** (journaux **Sécurité**).
Ouverture de session	Saisie via **Winlogon**, traitement par la **LSA**. Si domaine : **Kerberos** via **KDC**. Création d'un **jeton d'accès** (SID/privilèges).
Analyse incidents	Un nombre important d'**échecs d'authentification** peut indiquer une **erreur de configuration**, un **oubli de mot de passe** ou une **attaque par force brute**.

Pièges et confusions

- ⚠ Confondre l'authentification (vérification de l'identité) avec l'autorisation (détermination des droits).
- ⚠ Croire que le mot de passe représente l'identité lors des contrôles d'autorisation au lieu du jeton d'accès.
- ⚠ Penser que les autorisations sont associées au nom affiché du compte plutôt qu'aux SID.
- ⚠ Confondre le protocole Negotiate, qui sélectionne entre Kerberos et NTLM, avec un mécanisme créant de la sécurité.
- ⚠ Considérer que l'audit remplace la sécurité au lieu de permettre la détection d'incidents.

Sigles et définitions

Authentification	Processus consistant à vérifier l'identité d'un utilisateur, d'un ordinateur ou d'un service.
Autorisation	Action de déterminer les droits et les ressources auxquels une identité peut accéder après son authentification.
SID	Identificateur unique permettant à Windows d'identifier de manière unique un compte ou un groupe.
Jeton d'accès	Contexte de sécurité créé après une authentification réussie qui contient le SID de l'utilisateur, les SID des groupes et les privilèges.
SAM	Base qui contient les informations nécessaires à la gestion des comptes locaux sur un serveur autonome.
LSA	Composant central qui assure le traitement des demandes d'ouverture de session et la validation des informations d'identification.
SSPI	Interface commune permettant aux applications d'utiliser les mécanismes d'authentification Windows.
ACL	Liste de contrôle d'accès qui contient des entrées appelées ACE pour indiquer les droits accordés ou refusés sur un objet.

Auto-test

1. Quelle base contient les comptes locaux sur un serveur autonome ?
2. Quel protocole est privilégié dans un domaine Active Directory ?
3. Comment appelle-t-on les entrées d'une ACL ?
4. Quel composant est intégré aux contrôleurs de domaine pour Kerberos ?
5. Que permet de centraliser la GPO ?

Réponses : **1.** Le SAM · **2.** Kerberos · **3.** Des ACE · **4.** Le KDC · **5.** La configuration de sécurité des utilisateurs et des ordinateurs

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.